HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN

BÁO CÁO BÀI THỰC HÀNH
HỌC PHẦN: THỰC TẬP CƠ SỞ
MÃ HỌC PHẦN: INT13147

BÀI THỰC HÀNH 2.2
TÌM HIỂU VÀ CÀI ĐẶT, CẤU HÌNH NIDS

Sinh viên thực hiện:

B22DCAT303 - Nguyễn Khắc Trí

Giảng viên hướng dẫn: PGS. TS. Hoàng Xuân Dậu

HỌC KỲ 2 NĂM HỌC 2024-2025

MỤC LỤC

DANH MỤC CÁC HÌNH VẼ 3

DANH MỤC CÁC TỪ VIẾT TẮT 4

CHƯƠNG 1. GIỚI THIỆU CHUNG VỀ BÀI THỰC HÀNH 5

1.1 Mục đích 5

1.2 Tìm hiểu lý thuyết 5

1.2.1 Tìm hiểu khái quát về các hệ thống phát hiện tấn công, xâm nhập, phân loại các hệ thống phát hiện xâm nhập, các kỹ thuật phát hiện xâm nhập. 5

1.2.2 Tìm hiểu về kiến trúc và tính năng của một số hệ thống phát hiện tấn công, xâm nhập: Snort, OSSEC 7

CHƯƠNG 2. NỘI DUNG THỰC HÀNH 12

2.1 Chuẩn bị môi trường 12

2.2 Các bước thực hiện 12

TÀI LIỆU THAM KHẢO 19

DANH MỤC CÁC HÌNH VẼ

Hình 1 Hệ thống phát hiện xâm nhập (IDS - Intrusion Detection System) 5

Hình 2 Giá trị entropy của IP nguồn của các gói tin từ lưu lượng hợp pháp (phần giá trị cao, đều) và entropy của IP nguồn của các gói tin từ lưu lượng tấn công DDoS (phần giá trị thấp) 7

Hình 3 Kiến trúc của Snort 8

Hình 4 Kiến trúc và mô hình hoạt động của Ossec 10

Hình 5 Đổi tên máy Máy Kali Linux 12

Hình 6 Kiểm tra Ip 12

Hình 7 Sau khi đổi tên máy cài Snort, kiểm tra IP 13

Hình 8 Cài đặt Snort 13

Hình 9 Chạy thử Snort 14

Hình 10 Kiểm tra log của Snort 14

Hình 11 Tạo thêm luật 15

Hình 12 Kiểm tra cấu hình snort 16

Hình 13 Từ máy Kali sử dụng lệnh ping 16

Hình 14 Trên máy Snort kiểm tra kết quả 17

Hình 15 Từ máy Kali sử dụng công cụ nmap 17

Hình 16 Trên máy Snort kiểm tra kết quả 18

Hình 17 Từ máy Kali sử dụng công cụ hping3 18

Hình 18 Trên máy Snort kiểm tra kết quả 18

DANH MỤC CÁC TỪ VIẾT TẮT

Từ viết tắt	Thuật ngữ tiếng Anh/Giải thích	Thuật ngữ tiếng Việt/Giải thích
IDS	Intrusion Detection System	Hệ thống phát hiện xâm nhập
HIDS	Host-based Intrusion Detection System	Hệ thống phát hiện xâm nhập dựa trên máy chủ
NIDS	Network-based Intrusion Detection System	Hệ thống phát hiện xâm nhập dựa trên mạng
DDoS	Distributed Denial of Service	Tấn công từ chối dịch vụ phân tán
OSSEC	Open Source Security	Phần mềm mã nguồn mở phát hiện xâm nhập dựa trên máy chủ
TCP	Transmission Control Protocol	Giao thức điều khiển truyền tải

CHƯƠNG 1. GIỚI THIỆU CHUNG VỀ BÀI THỰC HÀNH

1.1 Mục đích

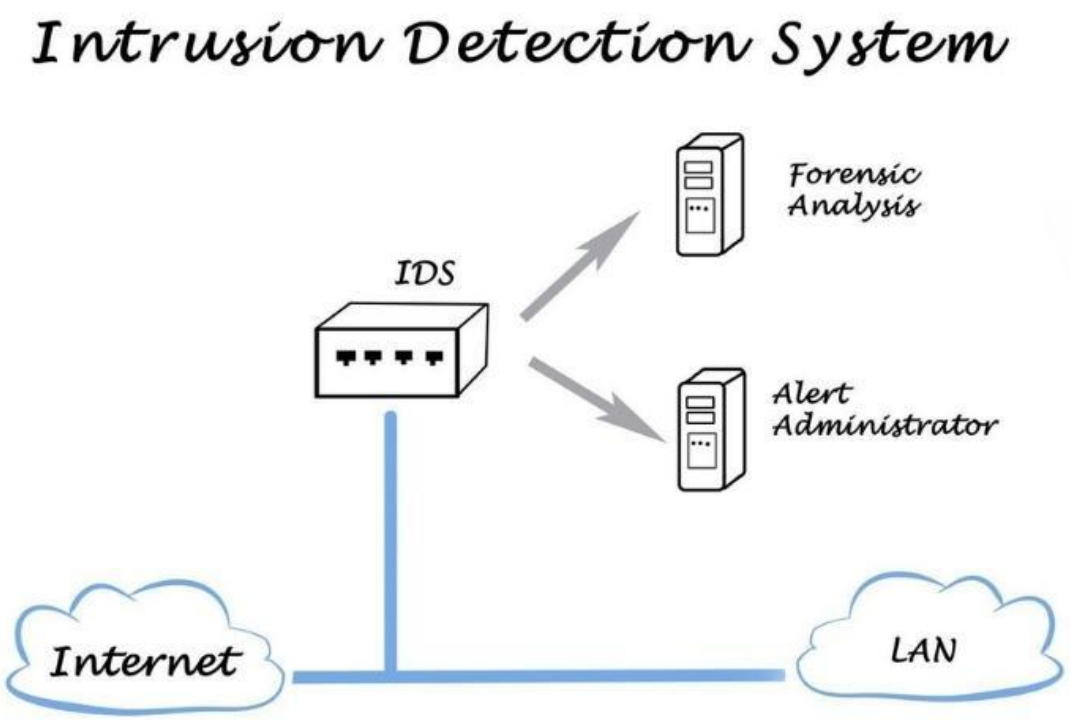
- Tìm hiểu và luyện tập việc cài đặt và vận hành các hệ thống phát hiện xâm nhập cho host (HIDS) và cho mạng (NIDS).
- Luyện tập việc tạo và chỉnh sửa các luật phát hiện tấn công, xâm nhập cho các hệ thống phát hiện xâm nhập thông dụng

1.2 Tìm hiểu lý thuyết

1.2.1 Tìm hiểu khái quát về các hệ thống phát hiện tấn công, xâm nhập, phân loại các hệ thống phát hiện xâm nhập, các kỹ thuật phát hiện xâm nhập.

1.2.1.1 Tổng quan về hệ thống phát hiện tấn công, xâm nhập (IDS)

Hệ thống phát hiện xâm nhập (IDS - Intrusion Detection System) là một công cụ an ninh mạng giúp giám sát, phân tích lưu lượng mạng hoặc nhật ký hệ thống để phát hiện các hành vi bất thường hoặc có khả năng gây hại.



Hình 1 Hệ thống phát hiện xâm nhập (IDS - Intrusion Detection System)

1.2.1.2 Phân loại các hệ thống phát hiện xâm nhập

IDS được chia thành hai loại chính:

- **HIDS (Host-based Intrusion Detection System)**: Giám sát các tệp log, thay đổi file, tiến trình, và các hoạt động khác trên một hệ thống máy chủ cụ thể.

- **NIDS (Network-based Intrusion Detection System)**: Giám sát lưu lượng mạng để phát hiện các cuộc tấn công bằng cách phân tích gói tin.

Theo phương pháp phân tích dữ liệu, có 2 kỹ thuật phân tích chính, gồm:

- Phát hiện xâm nhập dựa trên chữ ký, hoặc phát hiện sự lạm dụng (Signature-based / misuse intrusion detection)
- Phát hiện xâm nhập dựa trên các bất thường (Anomaly intrusion detection).

1.2.1.3 Các kỹ thuật phát hiện xâm nhập

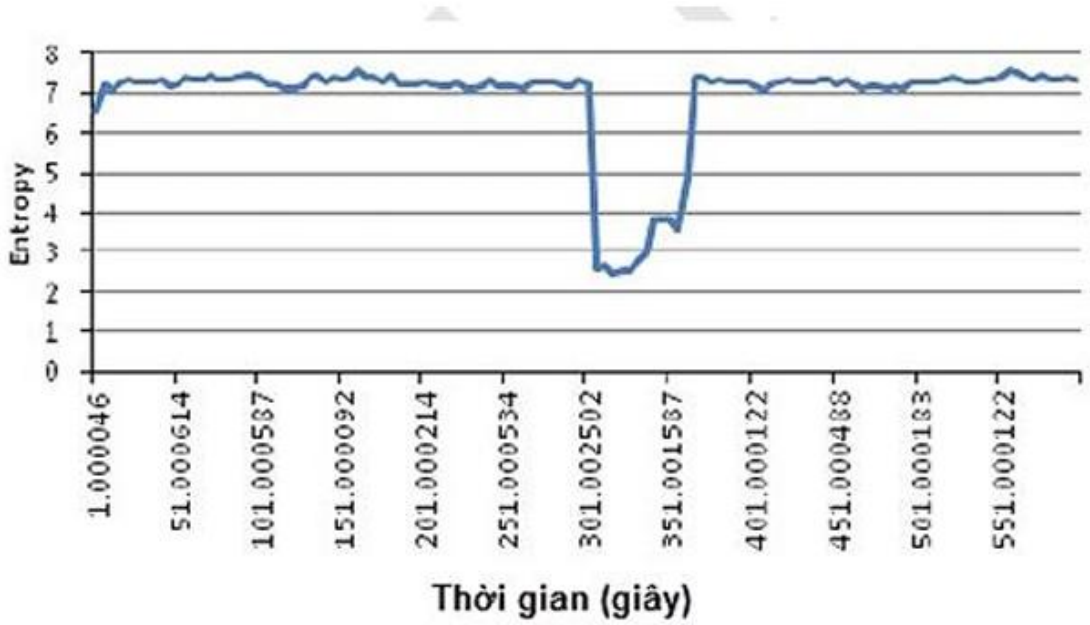
Phát hiện xâm nhập dựa trên chữ ký

Phát hiện xâm nhập dựa trên chữ ký trước hết cần xây dựng cơ sở dữ liệu các chữ ký, hoặc các dấu hiệu của các loại tấn công, xâm nhập đã biết. Hầu hết các chữ ký, dấu hiệu được nhận dạng và mã hóa thủ công và dạng biểu diễn thường gặp là các luật phát hiện (Detection rule). Bước tiếp theo là sử dụng cơ sở dữ liệu các chữ ký để giám sát các hành vi của hệ thống, hoặc mạng, và cảnh báo nếu phát hiện chữ ký của tấn công, xâm nhập. Hình dưới đây biểu diễn lưu đồ giám sát phát hiện tấn công, xâm nhập dựa trên chữ ký điển hình, trong đó Knowledge base là cơ sở dữ liệu lưu các chữ ký tấn công, xâm nhập.

Ưu điểm lớn nhất của phát hiện xâm nhập dựa trên chữ ký là có khả năng phát hiện các tấn công, xâm nhập đã biết một cách hiệu quả. Ngoài ra, phương pháp này cho tốc độ xử lý cao, đồng thời yêu cầu tài nguyên tính toán tương đối thấp. Nhờ vậy, các hệ thống phát hiện xâm nhập dựa trên chữ ký được ứng dụng rộng rãi trong thực tế. Tuy nhiên, nhược điểm chính của phương pháp này là không có khả năng phát hiện các tấn công, xâm nhập mới, do chữ ký của chúng chưa tồn tại trong cơ sở dữ liệu các chữ ký. Hơn nữa, phương pháp này cũng đòi hỏi nhiều công sức xây dựng và cập nhật cơ sở dữ liệu chữ ký, dấu hiệu của các tấn công, xâm nhập.

Phát hiện xâm nhập dựa trên bất thường

Phát hiện xâm nhập dựa trên bất thường dựa trên giả thiết: các hành vi tấn công, xâm nhập thường có quan hệ chặt chẽ với các hành vi bất thường. Quá trình xây dựng và triển khai một hệ thống phát hiện xâm nhập dựa trên bất thường thường gồm 2 giai đoạn: (1) huấn luyện và (2) phát hiện. Trong giai đoạn huấn luyện, hồ sơ (profile) của đối tượng trong chế độ làm việc bình thường được xây dựng. Để thực hiện giai đoạn huấn luyện, cần giám sát đối tượng trong một khoảng thời gian đủ dài để thu thập được đầy đủ dữ liệu mô tả các hành vi của đối tượng trong điều kiện bình thường làm dữ liệu huấn luyện. Tiếp theo, thực hiện huấn luyện dữ liệu để xây dựng mô hình phát hiện, hay hồ sơ của đối tượng. Trong giai đoạn phát hiện, thực hiện giám sát hành vi hiện tại của hệ thống và cảnh báo nếu có khác biệt rõ nét giữa hành vi hiện tại và các hành vi lưu trong hồ sơ của đối tượng.



Hình 2 Giá trị entropy của IP nguồn của các gói tin từ lưu lượng hợp pháp (phần giá trị cao, đều) và entropy của IP nguồn của các gói tin từ lưu lượng tấn công DDoS (phần giá trị thấp)

Hình trên biểu diễn giá trị entropy của IP nguồn của các gói tin theo cửa sổ trượt từ lưu lượng bình thường và entropy của IP nguồn của các gói tin từ lưu lượng tấn công DDoS. Có thể thấy sự khác biệt rõ nét giữa giá trị entropy của lưu lượng bình thường và lưu lượng tấn công và như vậy nếu một ngưỡng entropy được chọn phù hợp ta hoàn toàn có thể phát hiện sự xuất hiện của cuộc tấn công DDoS dựa trên sự thay đổi đột biến của giá trị entropy. Ưu điểm của phát hiện xâm nhập dựa trên bất thường là có tiềm năng phát hiện các loại tấn công, xâm nhập mới mà không yêu cầu biết trước thông tin về chúng. Tuy nhiên, phương pháp này thường có tỷ lệ cảnh báo sai tương đối cao so với phương pháp phát hiện dựa trên chữ ký. Điều này làm giảm khả năng ứng dụng thực tế của phát hiện xâm nhập dựa trên bất thường. Ngoài ra, phương pháp này cũng tiêu tốn nhiều tài nguyên hệ thống cho việc xây dựng hồ sơ đối tượng và phân tích hành vi hiện tại.

1.2.2 Tìm hiểu về kiến trúc và tính năng của một số hệ thống phát hiện tấn công, xâm nhập: Snort, OSSEC

1.2.2.1 Snort

Giới thiệu

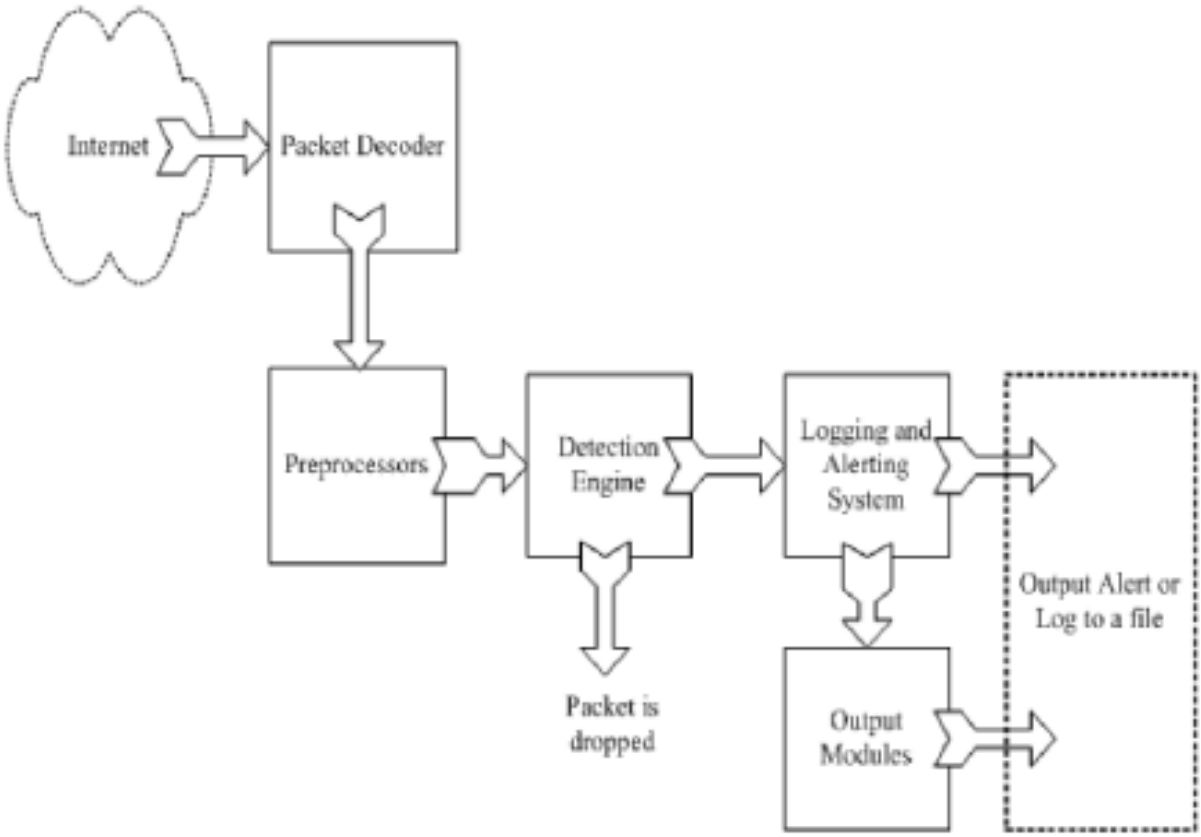
Snort là một công cụ IDS/IPS, thực hiện giám sát các gói tin ra vào hệ thống.

- Snort là một mã nguồn mở miễn phí với nhiều tính năng trong việc bảo vệ hệ thống bên trong, phát hiện sự tấn công từ bên ngoài vào hệ thống.
- Snort được viết bởi Martin Roesch vào năm 1998. Hiện tại, Snort được phát triển bởi Sourcefire, nơi mà Roesch đang là người sáng lập và CTO, và được sở hữu bởi Cisco từ năm 2013.

Kiến trúc của Snort

Trong mô hình kiến trúc trên, hệ thống Snort được chia thành 4 phần:

- Module Decoder: Xử lý giải mã các gói tin
- Module Preprocessors: Tiền xử lý
- Module Detection Engine: Phát hiện
- Module Logging and Alerting System: Lưu log và cảnh báo.



Hình 3 Kiến trúc của Snort

Các luật của Snort

Cấu trúc của một rule được chia thành 02 phần: |Rule header|Rule Option|

- Phần Header: Chứa thông tin về hành động mà luật đó sẽ thực hiện khi phát hiện ra có xâm nhập nằm trong gói tin và nó cũng chứa tiêu chuẩn để áp dụng luật với gói tin đó.
- Phần Option: Chứa thông điệp cảnh báo và các thông tin về các phần của gói tin dùng để tạo nên cảnh báo. Phần Option này chưa các tiêu chuẩn phụ thêm để đối sánh với gói tin

Cấu trúc phần Header: |Action|Protocol|Address|port|Direction|Address|Port|

- Action: Thể hiện hành động sẽ được thực hiện khi một gói tin kích hoạt quy tắc. Trong đó:
  - alert: Tạo một cảnh báo và ghi lại gói tin.
  - log: Chỉ ghi lại gói tin mà không tạo cảnh báo.
  - pass: Bỏ qua gói tin, không thực hiện hành động nào.

    - activate: Tạo ra cảnh báo và kích hoạt thêm các luật khác để kiểm tra thêm điều kiện của gói tin
        - dynamic: Đây là luật được gọi bởi các luật khác có Action khai báo là Activate
- Protocol: Xác định loại giao thức của gói tin, ví dụ: TCP, UDP, ICMP, hoặc any (tất cả).
- Source IP Address: Địa chỉ IP nguồn của gói tin.
- Source Port: Cổng nguồn của gói tin. Có thể là một số cụ thể hoặc từ khoảng cụ thể.
- Direction Operator: Thể hiện hướng của gói tin. Có thể là -> (nguồn tới đích) hoặc <- (đích tới nguồn).
- Destination IP Address: Địa chỉ IP đích của gói tin.
- Destination Port: Cổng đích của gói tin. Cũng có thể là một số cụ thể hoặc từ khoảng cụ thể.

Cấu trúc phần Option:

Phần Option nằm ngay sau phần Header và được bao bọc trong dấu ngoặc đơn. Nếu có nhiều Option thì sẽ phân biệt bởi dấu chấm phẩy ";". Một Option gồm có 2 phần: một là từ khóa và một là tham số. 02 phần này sẽ phân cách nhau bằng dấu hai chấm ":"

Các option có thể là: msg (tin nhắn cảnh báo), content (nội dung gói tin), sid (số nhận dạng duy nhất), rev (số phiên bản quy tắc), content: Chứa một chuỗi hoặc byte pattern để so khớp với dữ liệu gói tin …

Ví dụ về cấu trúc một quy tắc Snort:

alert tcp any any -> any 80 (msg:"Potential Web Attack"; content:"/bin/bash"; sid:100001;)

1.2.2.2 Ossec

Ossec là gì?

OSSEC là phần mềm mã nguồn mở giúp phát hiện xâm nhập dựa trên host (HIDS) Nó đa nền tảng, có thể mở rộng và có nhiều cơ chế bảo mật khác nhau.

Các tính năng của Ossec

- Log based Intrusion Detection (LIDs) and Log Monitoring:
    - Chủ động theo dõi và phân tích dữ liệu real-time từ nhiều nguồn sinh log.
    - Ngoài ra, Ossec sẽ thu thập, phân tích và kiểm tra mối tương quan các log và cho ta biết những điều đáng ngờ đang xảy ra trong hệ thống (bị tấn công, lỗi, sử dụng sai,..), các phần mềm được cài đặt thêm, các rule firewall bị đổi.
- Compliance Auditing:
    - Kiểm soát các ứng dụng và hệ thống nhằm tuân thủ các yêu cầu, tiêu chuẩn về bảo mật như PCI-DSS và CIS.
- Rootkit and Malware Detection:
    - Tin tặc thường muốn che dấu hành động và quay lại hệ thống đã xâm nhập được

    - Ossec phân tích ở cấp độ file và tiến trình nhằm phát hiện các ứng dụng độc hại, các rootkit hay các file hệ thống bị sửa đổi theo cách phổ biến với rootkit
- File Integrity Monitoring (FIM):
    - Phát hiện các thay đổi đối với hệ thống.
- Active Response:
    - Các hành vi ứng phó lại các cuộc tấn công vào hệ thống trong thời gian thực.
    - Giúp ngăn sự cố lan rộng trước khi admin có thể hành động
- System Inventory:
    - Thu thập các thông tin hệ thống như phần mềm được cài đặt, harware,…

Điểm nổi trội của Ossec

- Đa nền tảng (Linux, Mac OS, Window, Solaris)
- Real-time Alert (Cảnh báo thời gian thực)
    - Kết hợp với smtp, sms, syslog sẽ cho phép người dùng nhận cảnh báo trên các thiết bị có hỗ trợ email
    - Ngoài ra tính năng Active-respone có thể giúp block 1 cuộc tấn công ngay lập tức.
- Có thể tích hợp với các hệ thống hiện đại (SIM/SEM)
- Mô hình Server-Agent/Agentless, cho phép Server dễ dàng quản lý tập trung các chính sách trên nhiều OS.
- Giám sát trên agent, agentless (Client không cài đặt được gói agent) như router, firewall

Kiến trúc và mô hình hoạt động của Ossec

Hình 4 Kiến trúc và mô hình hoạt động của Ossec

Ossec hoạt động theo mô hình Server-Agent/Agentles

- **Manager (Server)**

Lưu trữ cơ sở dữ liệu của việc kiểm tra tính toàn vẹn file Kiểm tra các log, event. Quản lý, lưu tất cả các rule, decoder (bộ giải mã), cấu hình chính. Điều này giúp dễ dàng quản lý, dù cho có lượng lớn Agent Server không chạy trên Windows OS.

- **Agent**

Bản chất thì là 1 phần mềm được cài đặt trên máy client giúp thu thập các thông tin và gửi cho Server để phân tích, thống kê.

  - Chiếm lượng memory và CPU nhỏ, không đáng kể
  - 1 số thông tin được thu thập theo thời gian thực
  - 1 số thông tin thì lại được thu thập định kỳ

Nhưng khi nói Agent thì là để chỉ máy Client được cài gói Ossec-agent. Chú ý: Windows OS chỉ có thể làm Agent chứ không làm Server được.

- **Agentless**

Là các hệ thống không cài được gói agent Trên các Agentless này có thể thực hiện việc kiểm tra tính toàn vẹn Giúp monitor firewall, router hay thậm chí cả hệ thống Unix

- **Ảo hóa/ VMware**

Cho phép cài đặt agent trên các guest OS (Máy ảo) Ngoài ra cũng được cài đặt trong VMware ESX nhưng có thể dẫn đến sự cố không hỗ trợ. Khi cài đặt trong VMware ESX giúp nhận được thời điểm các VM guest được khởi tạo, xóa đi, khởi động,.. Ossec cũng giám sát việc login, logouts và các lỗi bên trong ESX server Ngoài ra nó cũng cảnh báo nếu bất kỳ tùy chọn cấu hình không an toàn nào được bật.

- **Firewalls, switches and routers**

Chính là các Agentless Ossec có thể nhận và phân tích nhật ký hệ thống từ nhiều firewall, switch, router. Nó support tất cả Cisco routers, Cisco PIX, Cisco FWSM, Cisco ASA, Juniper Routers, Netscreen firewall, Checkpoint và nhiều thiết bị khác.

CHƯƠNG 2. NỘI DUNG THỰC HÀNH

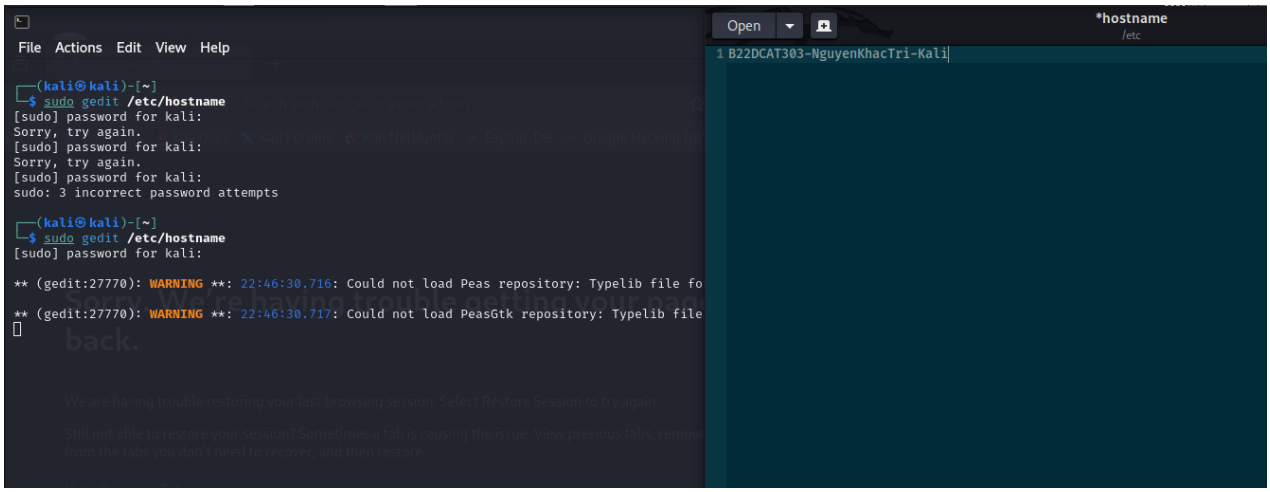
2.1 Chuẩn bị môi trường

- 01 máy tính (máy thật hoặc máy ảo) chạy Linux với RAM tối thiểu 2GB, 10GB đĩa cứng có kết nối mạng (LAN hoặc Internet):
- 01 máy tính (máy thật hoặc máy ảo) chạy Kali Linux (bản 2021 trở lên)
- Bộ phần mềm Snort

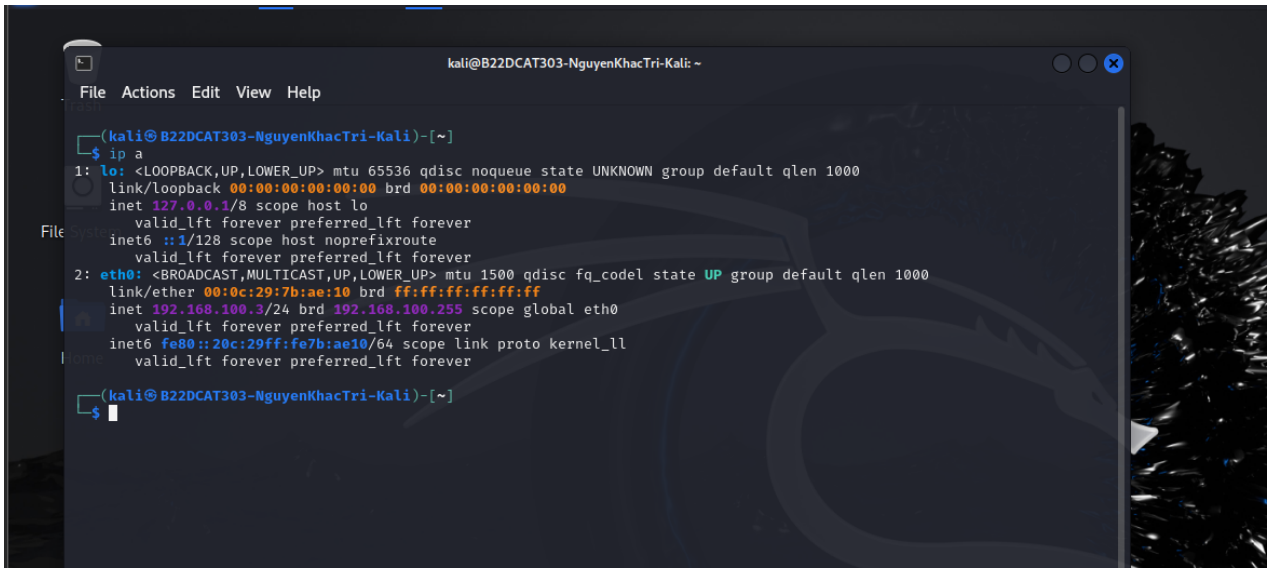
2.2 Các bước thực hiện

Bước 1:

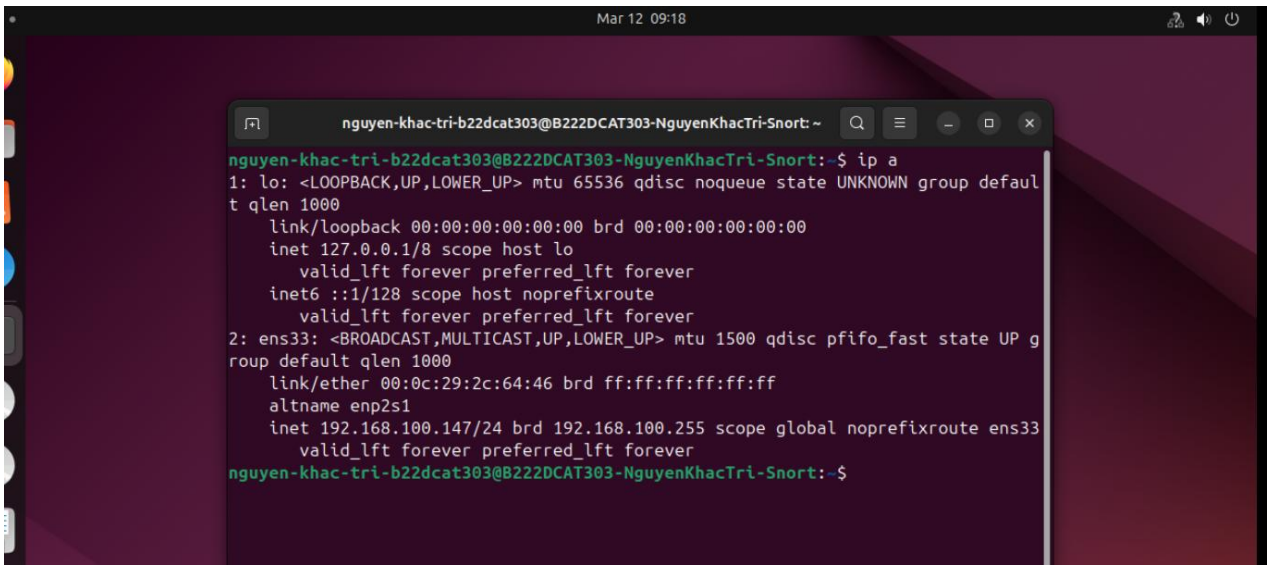
Chuẩn bị các máy tính như mô tả trong mục 2.1 Máy Kali Linux được đổi tên thành B22CAT303-NguyenKhacTri-Kali và máy cài Snort thành B22CAT303-NguyenKhacTri-Snort. Các máy có địa chỉ IP và kết nối mạng LAN.



Hình 5 Đổi tên máy Máy Kali Linux



Hình 6 Kiểm tra Ip



Hình 7 Sau khi đổi tên máy cài Snort, kiểm tra IP

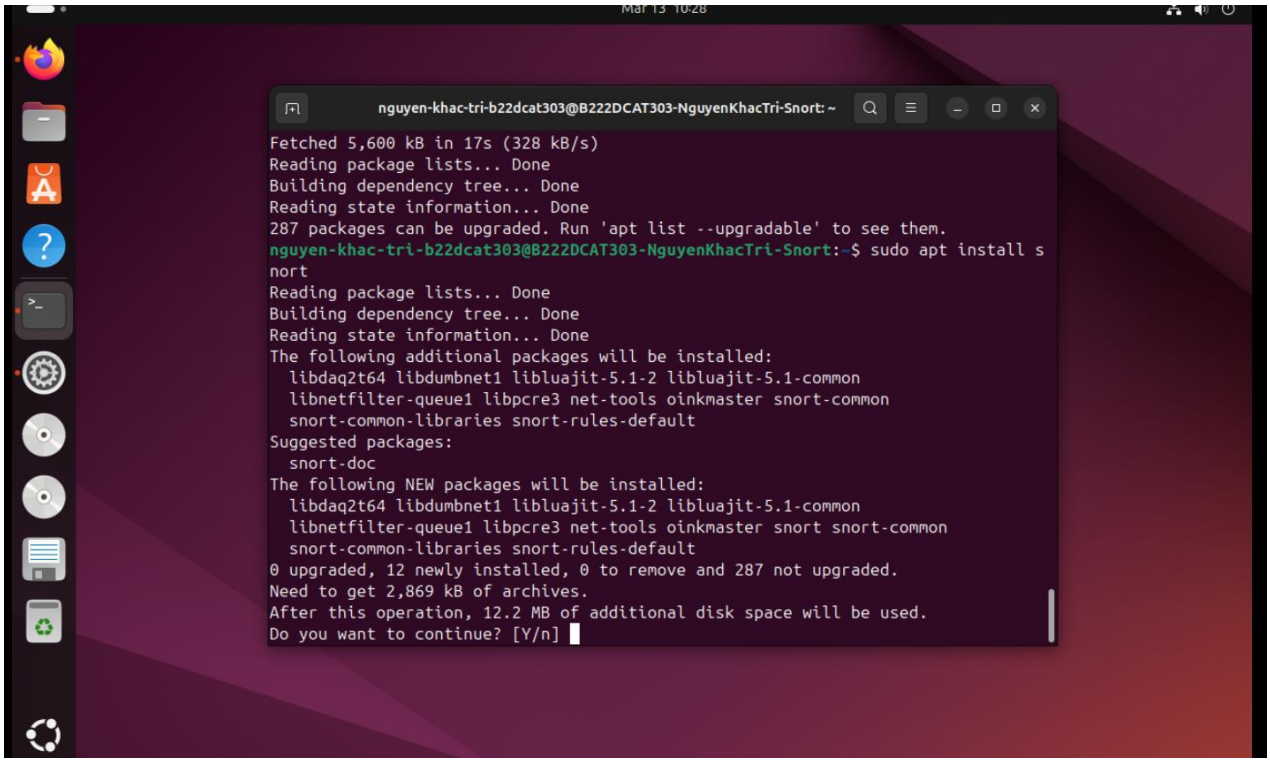
Bước 2:

Tải, cài đặt Snort và chạy thử Snort. Kiểm tra log của Snort để đảm bảo Snort hoạt động bình thường.

Tải snort:

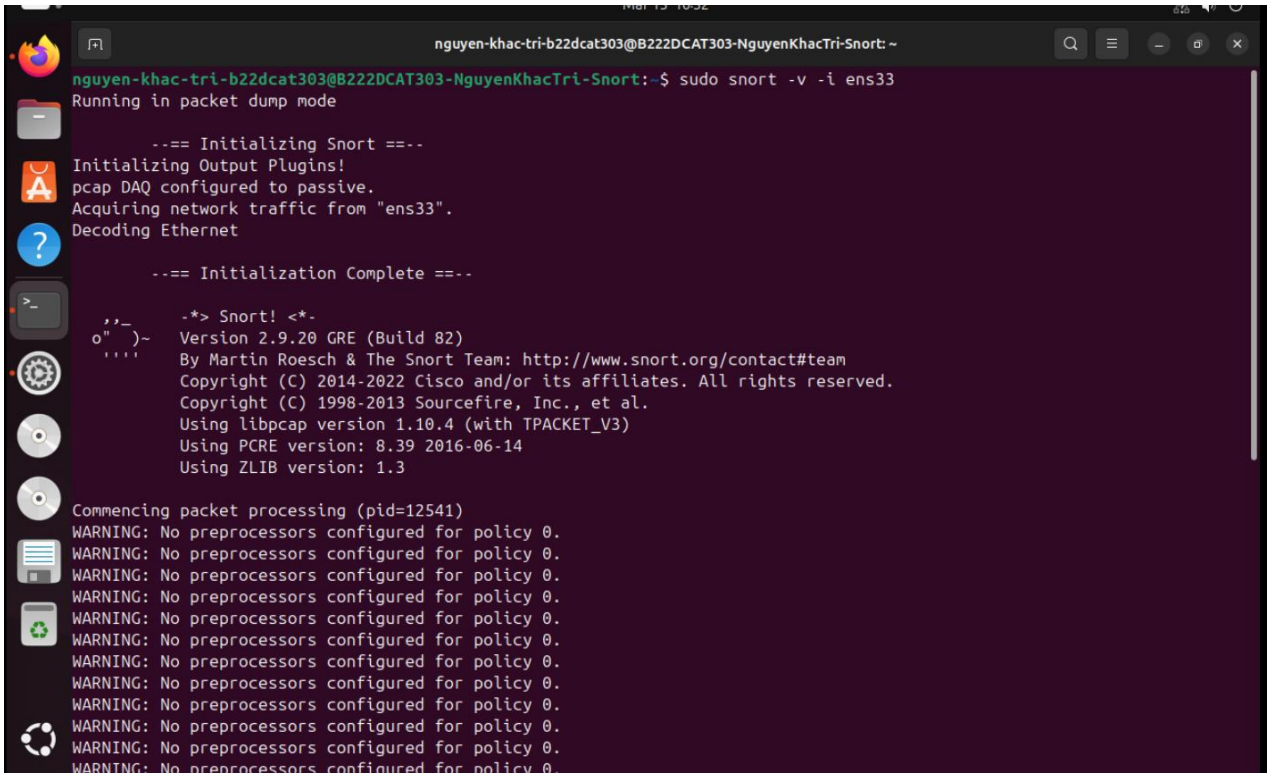
sudo apt update

sudo apt install snort



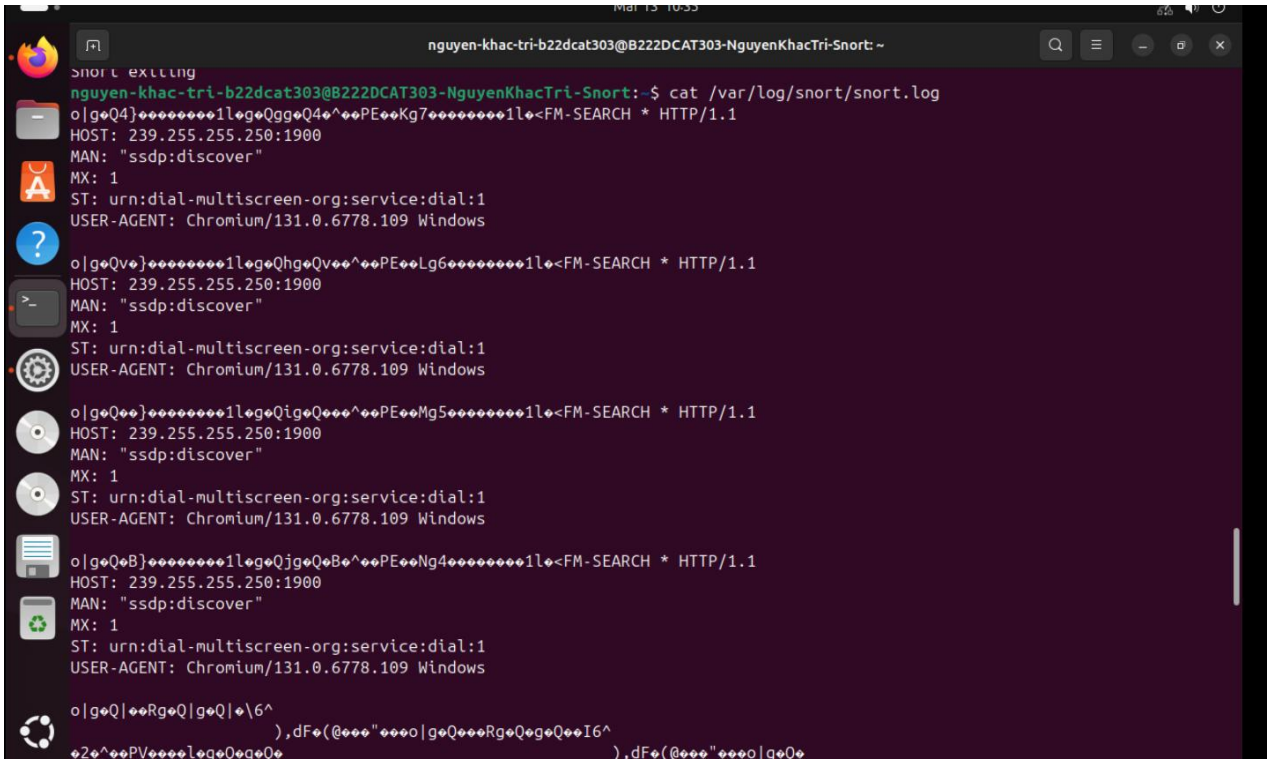
Hình 8 Cài đặt Snort

Chạy thử Snort



Hình 9 Chạy thử Snort

Kiểm tra log của Snort



Hình 10 Kiểm tra log của Snort

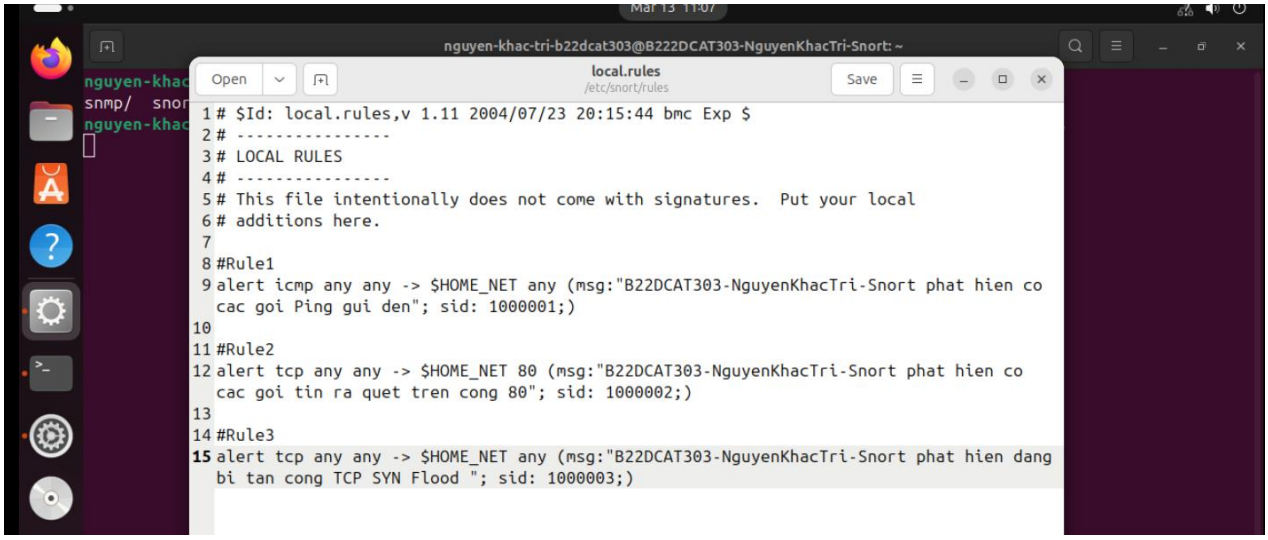
Bước 3

Tạo các luật Snort để phát hiện 3 dạng rà quét, tấn công hệ thống:

- Phát hiện các gói tin ping từ bất kỳ một máy nào gửi đến máy chạy Snort. Hiển thị thông điệp khi phát hiện: “B22CAT303-NguyenKhacTri -Snort phát hiện có các gói Ping gửi đến.”
- Phát hiện các gói tin rà quét từ bất kỳ một máy nào gửi đến máy chạy Snort trên cổng 80. Hiển thị thông điệp khi phát hiện: “B22CAT303-NguyenKhacTri-Snort phát hiện có các gói tin rà quét trên cổng 80.”
- Phát hiện tấn công TCP SYN Flood từ bất kỳ một máy nào gửi đến máy chạy Snort. Hiển thị thông điệp khi phát hiện: “B22CAT303-NguyenKhacTri -Snort phát hiện đang bị tấn công TCP SYN Flood.”

Mở file để tạo thêm luật:

sudo gedit /etc/snort/rules/local.rules



Hình 11 Tạo thêm luật

Kiểm tra cấu hình snort: sudo snort -T -c /etc/snort/snort.conf

```
nguyen-khac-tri-b22dcat303@B222DCAT303-NguyenKhacTri-Snort:~$ sudo snort -T -c /etc/snort/snort.conf
Running in Test mode

        --== Initializing Snort ==--
Initializing Output Plugins!
Initializing Preprocessors!
Initializing Plug-ins!
Parsing Rules file "/etc/snort/snort.conf"
PortVar 'HTTP_PORTS' defined :  [ 80:81 311 383 591 593 901 1220 1414 1741 1830 2301 2381 2809 3037 3128 3702 4343 4848
5250 6988 7000:7001 7144:7145 7510 7777 7779 8000 8008 8014 8028 8080 8085 8088 8090 8118 8123 8180:8181 8243 8280 8300
8800 8888 8899 9000 9060 9080 9090:9091 9443 9999 11371 34443:34444 41080 50002 55555 ]
PortVar 'SHELLCODE_PORTS' defined :  [ 0:79 81:65535 ]
PortVar 'ORACLE_PORTS' defined :  [ 1024:65535 ]
PortVar 'SSH_PORTS' defined :  [ 22 ]
PortVar 'FTP_PORTS' defined :  [ 21 2100 3535 ]
PortVar 'SIP_PORTS' defined :  [ 5060:5061 5600 ]
PortVar 'FILE_DATA_PORTS' defined :  [ 80:81 110 143 311 383 591 593 901 1220 1414 1741 1830 2301 2381 2809 3037 3128 37
02 4343 4848 5250 6988 7000:7001 7144:7145 7510 7777 7779 8000 8008 8014 8028 8080 8085 8088 8090 8118 8123 8180:8181 82
43 8280 8300 8800 8888 8899 9000 9060 9080 9090:9091 9443 9999 11371 34443:34444 41080 50002 55555 ]
PortVar 'GTP_PORTS' defined :  [ 2123 2152 3386 ]
Detection:
   Search-Method = AC-Full-Q
    Split Any/Any group = enabled
    Search-Method-Optimizations = enabled
    Maximum pattern length = 20
Tagged Packet Limit: 256
Loading dynamic engine /usr/lib/snort/snort_dynamicengine/libsf_engine.so... done
Loading all dynamic detection libs from /usr/lib/snort/snort_dynamicrules...
WARNING: No dynamic libraries found in directory /usr/lib/snort/snort_dynamicrules.
  Finished Loading all dynamic detection libs from /usr/lib/snort/snort_dynamicrules
Loading all dynamic preprocessor libs from /usr/lib/snort/snort_dynamicpreprocessor/...
  Loading dynamic preprocessor library /usr/lib/snort/snort_dynamicpreprocessor//libsf_sdf_preproc.so... done
```

Hình 12 Kiểm tra cấu hình snort

Bước 4:

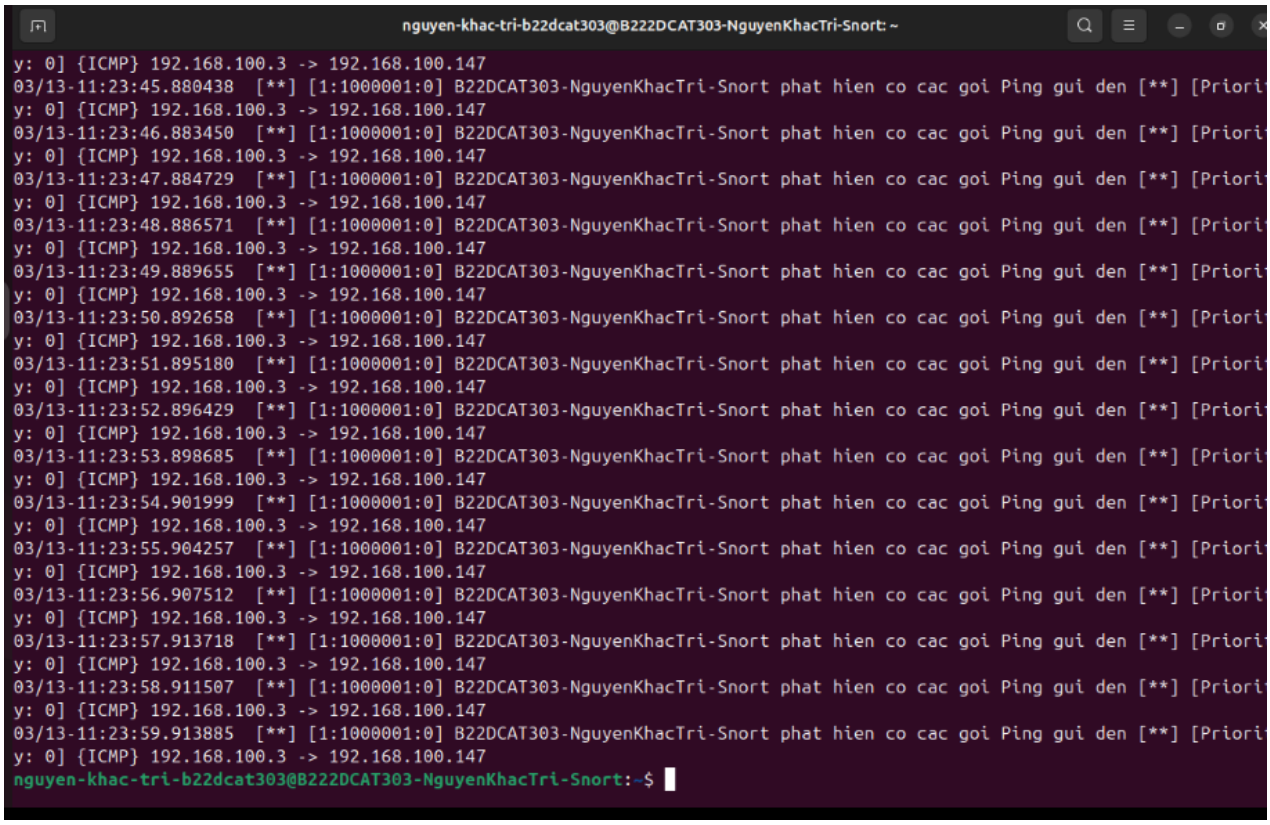
Thực thi tấn công và phát hiện sử dụng Snort.

Từ máy Kali, sử dụng lệnh ping để ping máy Snort.

```
kali@B22DCAT303-NguyenKhacTri-Kali: ~
File  Actions  Edit  View  Help
┌──(kali㉿B22DCAT303-NguyenKhacTri-Kali)-[~]
└─$ ping 192.168.100.147
PING 192.168.100.147 (192.168.100.147) 56(84) bytes of data.
64 bytes from 192.168.100.147: icmp_seq=1 ttl=64 time=15.1 ms
64 bytes from 192.168.100.147: icmp_seq=2 ttl=64 time=2.67 ms
64 bytes from 192.168.100.147: icmp_seq=3 ttl=64 time=4.51 ms
64 bytes from 192.168.100.147: icmp_seq=4 ttl=64 time=2.96 ms
64 bytes from 192.168.100.147: icmp_seq=5 ttl=64 time=2.74 ms
64 bytes from 192.168.100.147: icmp_seq=6 ttl=64 time=2.15 ms
64 bytes from 192.168.100.147: icmp_seq=7 ttl=64 time=1.50 ms
64 bytes from 192.168.100.147: icmp_seq=8 ttl=64 time=3.79 ms
64 bytes from 192.168.100.147: icmp_seq=9 ttl=64 time=2.02 ms
64 bytes from 192.168.100.147: icmp_seq=10 ttl=64 time=3.67 ms
64 bytes from 192.168.100.147: icmp_seq=11 ttl=64 time=2.45 ms
64 bytes from 192.168.100.147: icmp_seq=12 ttl=64 time=2.11 ms
64 bytes from 192.168.100.147: icmp_seq=13 ttl=64 time=2.34 ms
64 bytes from 192.168.100.147: icmp_seq=14 ttl=64 time=2.93 ms
64 bytes from 192.168.100.147: icmp_seq=15 ttl=64 time=3.24 ms
64 bytes from 192.168.100.147: icmp_seq=16 ttl=64 time=1.84 ms
64 bytes from 192.168.100.147: icmp_seq=17 ttl=64 time=1.84 ms
64 bytes from 192.168.100.147: icmp_seq=18 ttl=64 time=2.11 ms
64 bytes from 192.168.100.147: icmp_seq=19 ttl=64 time=1.68 ms
64 bytes from 192.168.100.147: icmp_seq=20 ttl=64 time=3.50 ms
64 bytes from 192.168.100.147: icmp_seq=21 ttl=64 time=6.93 ms
64 bytes from 192.168.100.147: icmp_seq=22 ttl=64 time=2.48 ms
64 bytes from 192.168.100.147: icmp_seq=23 ttl=64 time=2.54 ms
64 bytes from 192.168.100.147: icmp_seq=24 ttl=64 time=4.29 ms
64 bytes from 192.168.100.147: icmp_seq=25 ttl=64 time=4.26 ms
64 bytes from 192.168.100.147: icmp_seq=26 ttl=64 time=2.28 ms
64 bytes from 192.168.100.147: icmp_seq=27 ttl=64 time=2.53 ms
64 bytes from 192.168.100.147: icmp_seq=28 ttl=64 time=1.81 ms
64 bytes from 192.168.100.147: icmp_seq=29 ttl=64 time=2.34 ms
```

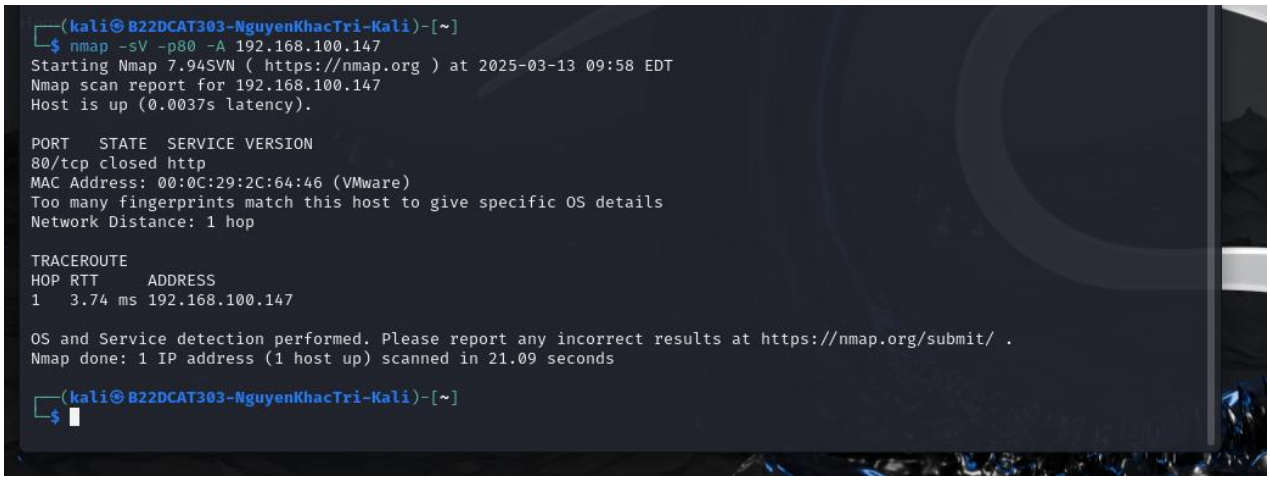
Hình 13 Từ máy Kali sử dụng lệnh ping

Trên máy Snort kiểm tra kết quả phát hiện trên giao diện terminal hoặc log của Snort.



Hình 14 Trên máy Snort kiểm tra kết quả

Từ máy Kali, sử dụng công cụ nmap để rà quét máy Snort (dùng lệnh: nmap -sV -p80 -A 192.168.100.147)



Hình 15 Từ máy Kali sử dụng công cụ nmap

Trên máy Snort kiểm tra kết quả phát hiện trên giao diện terminal hoặc log của Snort.

```
03/13-11:27:40.339096  [**] [1:1000001:0] B22DCAT303-NguyenKhacTri-Snort phat hien co cac goi Ping gui den [**] [Priorit
y: 0] {ICMP} 192.168.100.3 -> 192.168.100.147
03/13-11:27:40.364307  [**] [1:1000001:0] B22DCAT303-NguyenKhacTri-Snort phat hien co cac goi Ping gui den [**] [Priorit
y: 0] {ICMP} 192.168.100.3 -> 192.168.100.147
03/13-11:27:40.417602  [**] [1:1000003:0] B22DCAT303-NguyenKhacTri-Snort phat hien dang bi tan cong TCP SYN Flood  [**]
[Priority: 0] {TCP} 192.168.100.3:41171 -> 192.168.100.147:80
03/13-11:27:40.417602  [**] [1:1000002:0] B22DCAT303-NguyenKhacTri-Snort phat hien co cac goi tin ra quet tren cong 80 [
**] [Priority: 0] {TCP} 192.168.100.3:41171 -> 192.168.100.147:80
03/13-11:27:40.442532  [**] [1:1000003:0] B22DCAT303-NguyenKhacTri-Snort phat hien dang bi tan cong TCP SYN Flood  [**]
[Priority: 0] {TCP} 192.168.100.3:41172 -> 192.168.100.147:80
03/13-11:27:40.442532  [**] [1:1000002:0] B22DCAT303-NguyenKhacTri-Snort phat hien co cac goi tin ra quet tren cong 80 [
**] [Priority: 0] {TCP} 192.168.100.3:41172 -> 192.168.100.147:80
03/13-11:27:40.468352  [**] [1:1000003:0] B22DCAT303-NguyenKhacTri-Snort phat hien dang bi tan cong TCP SYN Flood  [**]
[Priority: 0] {TCP} 192.168.100.3:41173 -> 192.168.100.147:80
03/13-11:27:40.468352  [**] [1:1000002:0] B22DCAT303-NguyenKhacTri-Snort phat hien co cac goi tin ra quet tren cong 80 [
**] [Priority: 0] {TCP} 192.168.100.3:41173 -> 192.168.100.147:80
03/13-11:27:40.468352  [**] [1:1228:7] SCAN nmap XMAS [**] [Classification: Attempted Information Leak] [Priority: 2] {T
CP} 192.168.100.3:41173 -> 192.168.100.147:80
nguyen-khac-tri-b22dcat303@B222DCAT303-NguyenKhacTri-Snort:~$
```

Hình 16 Trên máy Snort kiểm tra kết quả

Từ máy Kali, sử dụng công cụ hping3 để tấn công TCP SYN Flood máy Snort (dùng lệnh: hping3 -c 15000 -d 120 -S -w 64 -p 80 --flood --rand-source 192.168.100.147).

```
┌──(kali㉿B22DCAT303-NguyenKhacTri-Kali)-[~]
└─$ sudo hping3 -c 15000 -d 120 -S -w 64 -p 80 --flood --rand-source 192.168.100.147
[sudo] password for kali:
HPING 192.168.100.147 (eth0 192.168.100.147): S set, 40 headers + 120 data bytes
hping in flood mode, no replies will be shown
^C
--- 192.168.100.147 hping statistic ---
8020 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms

┌──(kali㉿B22DCAT303-NguyenKhacTri-Kali)-[~]
└─$
```

Hình 17 Từ máy Kali sử dụng công cụ hping3

Trên máy Snort kiểm tra kết quả phát hiện trên giao diện terminal hoặc log của Snort.

```
nguyen-khac-tri-b22dcat303@B222DCAT303-NguyenKhacTri-Snort: ~
[Priority: 0] {TCP} 34.151.5.49:9667 -> 192.168.100.147:80
03/13-11:33:14.117148  [**] [1:1000002:0] B22DCAT303-NguyenKhacTri-Snort phat hien co cac goi tin ra quet tren cong 80 [
**] [Priority: 0] {TCP} 34.151.5.49:9667 -> 192.168.100.147:80
03/13-11:33:14.117312  [**] [1:1000003:0] B22DCAT303-NguyenKhacTri-Snort phat hien dang bi tan cong TCP SYN Flood  [**]
[Priority: 0] {TCP} 220.125.221.69:9668 -> 192.168.100.147:80
03/13-11:33:14.117312  [**] [1:1000002:0] B22DCAT303-NguyenKhacTri-Snort phat hien co cac goi tin ra quet tren cong 80 [
**] [Priority: 0] {TCP} 220.125.221.69:9668 -> 192.168.100.147:80
03/13-11:33:14.118100  [**] [1:1000003:0] B22DCAT303-NguyenKhacTri-Snort phat hien dang bi tan cong TCP SYN Flood  [**]
[Priority: 0] {TCP} 169.178.161.95:9669 -> 192.168.100.147:80
03/13-11:33:14.118100  [**] [1:1000002:0] B22DCAT303-NguyenKhacTri-Snort phat hien co cac goi tin ra quet tren cong 80 [
**] [Priority: 0] {TCP} 169.178.161.95:9669 -> 192.168.100.147:80
03/13-11:33:14.118136  [**] [1:1000003:0] B22DCAT303-NguyenKhacTri-Snort phat hien dang bi tan cong TCP SYN Flood  [**]
[Priority: 0] {TCP} 125.106.67.82:9670 -> 192.168.100.147:80
03/13-11:33:14.118136  [**] [1:1000002:0] B22DCAT303-NguyenKhacTri-Snort phat hien co cac goi tin ra quet tren cong 80 [
**] [Priority: 0] {TCP} 125.106.67.82:9670 -> 192.168.100.147:80
03/13-11:33:14.118574  [**] [1:1000003:0] B22DCAT303-NguyenKhacTri-Snort phat hien dang bi tan cong TCP SYN Flood  [**]
[Priority: 0] {TCP} 169.152.104.149:9671 -> 192.168.100.147:80
03/13-11:33:14.118574  [**] [1:1000002:0] B22DCAT303-NguyenKhacTri-Snort phat hien co cac goi tin ra quet tren cong 80 [
**] [Priority: 0] {TCP} 169.152.104.149:9671 -> 192.168.100.147:80
03/13-11:33:14.118609  [**] [1:1000003:0] B22DCAT303-NguyenKhacTri-Snort phat hien dang bi tan cong TCP SYN Flood  [**]
[Priority: 0] {TCP} 161.159.32.208:9672 -> 192.168.100.147:80
03/13-11:33:14.118609  [**] [1:1000002:0] B22DCAT303-NguyenKhacTri-Snort phat hien co cac goi tin ra quet tren cong 80 [
```

Hình 18 Trên máy Snort kiểm tra kết quả

TÀI LIỆU THAM KHẢO

[1] Chương 5, Giáo trình Cơ sở an toàn thông tin, Học viện Công nghệ BVCT, 2020.

[2] Suricata: https://suricata.io/documentation/

[3] Snort: https://www.snort.org/#documents

[4] OSSEC: https://www.ossec.net/docs/

[5] Wazuh: https://documentation.wazuh.com/current/index.html